

Secure Enclave – Team Design Document

Introduction

This document details our team’s secure enclave design that will be used for storing artefacts relating to copywritten music. Primary concerns were creating a straightforward application and having security built into the design.

Security Considerations

To achieve this goal, the team considered elements of OWASP’s Top Ten Proactive Security Controls (OWASP, 2024). The following table shows implementations.

Control	Implementations
C1: Implement Access Control	Role-Based Access Control.
C2: Use Cryptography to Protect Data	Encryption service in design.
C3: Validate all Input and Handle Exceptions	Perform file validation.
	Use parameterized queries in database to mitigate SQL injection attacks (Odeh and Hijazi, 2023).
	Return non-specific error messages. This prevents giving system information to an attacker (Poston, 2020).
C4: Address Security from the Start	Create a security-focused design.
	Use trusted libraries.

Table 01: OWASP Top Ten Proactive Security Controls

Use Case Diagram

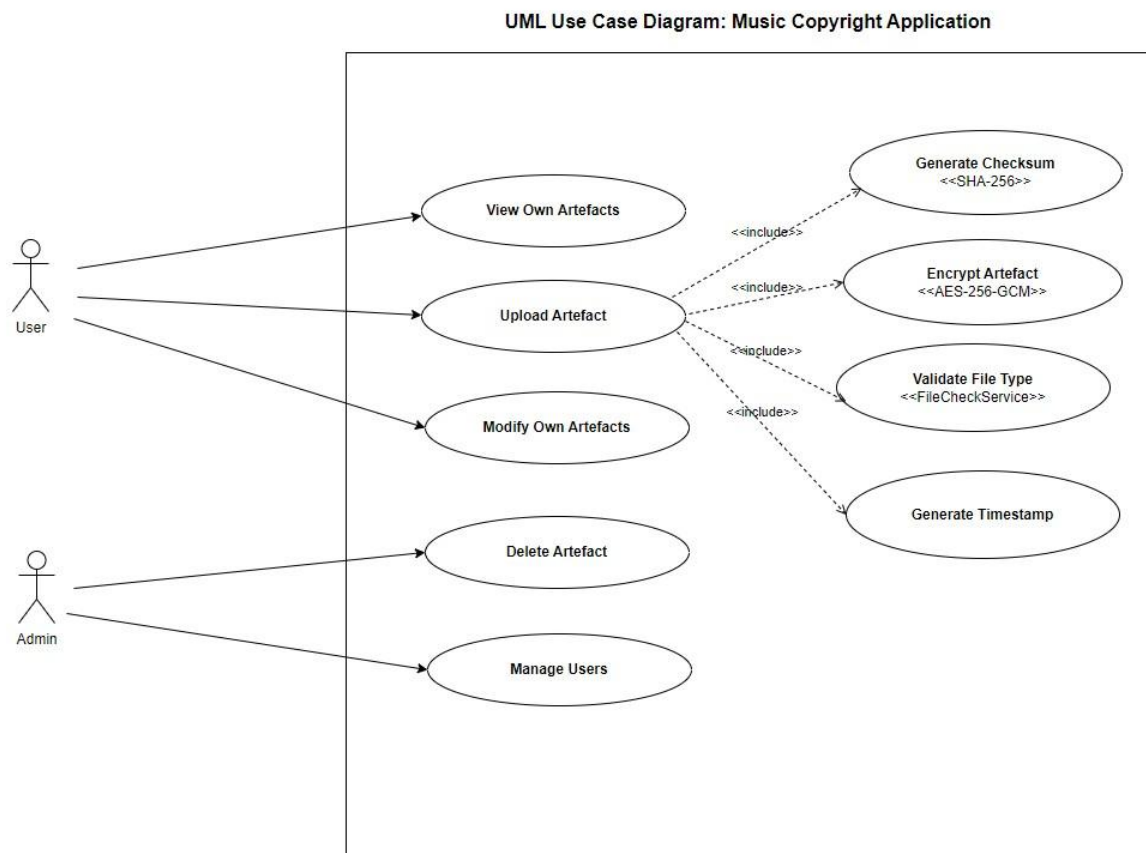


Figure 01: Use Case Diagram

Principal actors and their potential actions are represented:

- **User:** Uploads, views, and modifies their digital artefacts. Restricted from deleting artefacts and accessing the artefacts of others.
- **Admin:** Uses elevated privileges to delete artefacts and manage user accounts.

This aligns with Role-Based Access Control (RBAC) models, a key mechanism for enforcing least privilege within secure system design (Ferraiolo et al., 2023).

Following artefact upload, automated services are implemented:

File Validation

Uploaded files are subject to file validation and checked for size, guarding against malicious attacks and preventing database overload (OWASP, 2025).

Checksum Generation

A cryptographic hash function is applied using a library, facilitating file integrity validation and ensuring tampering is detectable (Garg et al., 2023). The security of this function depends on the use of collision-resistant algorithms—SHA-256 which is considered secure (NIST, 2023).

Encryption

Artefacts are encrypted before storage to ensure confidentiality, using a library supporting AES-256. Symmetric encryption is favoured for its performance in storing large files, however, its security relies on robust key management (Khan et al., 2022).

Timestamping

Timestamps are recorded on upload, creating an audit trail that can serve as digital evidence in copyright disputes (Zhou et al., 2023).

This supports the CIA Triad—confidentiality, integrity, and availability through secure artefact management. It also addresses non-repudiation, which is crucial in digital rights management (Sharma & Verma, 2022).

Upon modification, a new checksum and timestamp are generated, enforcing data provenance, fundamental for legal and forensic validity (Liu et al., 2023).

System Design

This diagram shows the application's design structure and actor relationships.

UML Class Diagram - Music Copyright Application

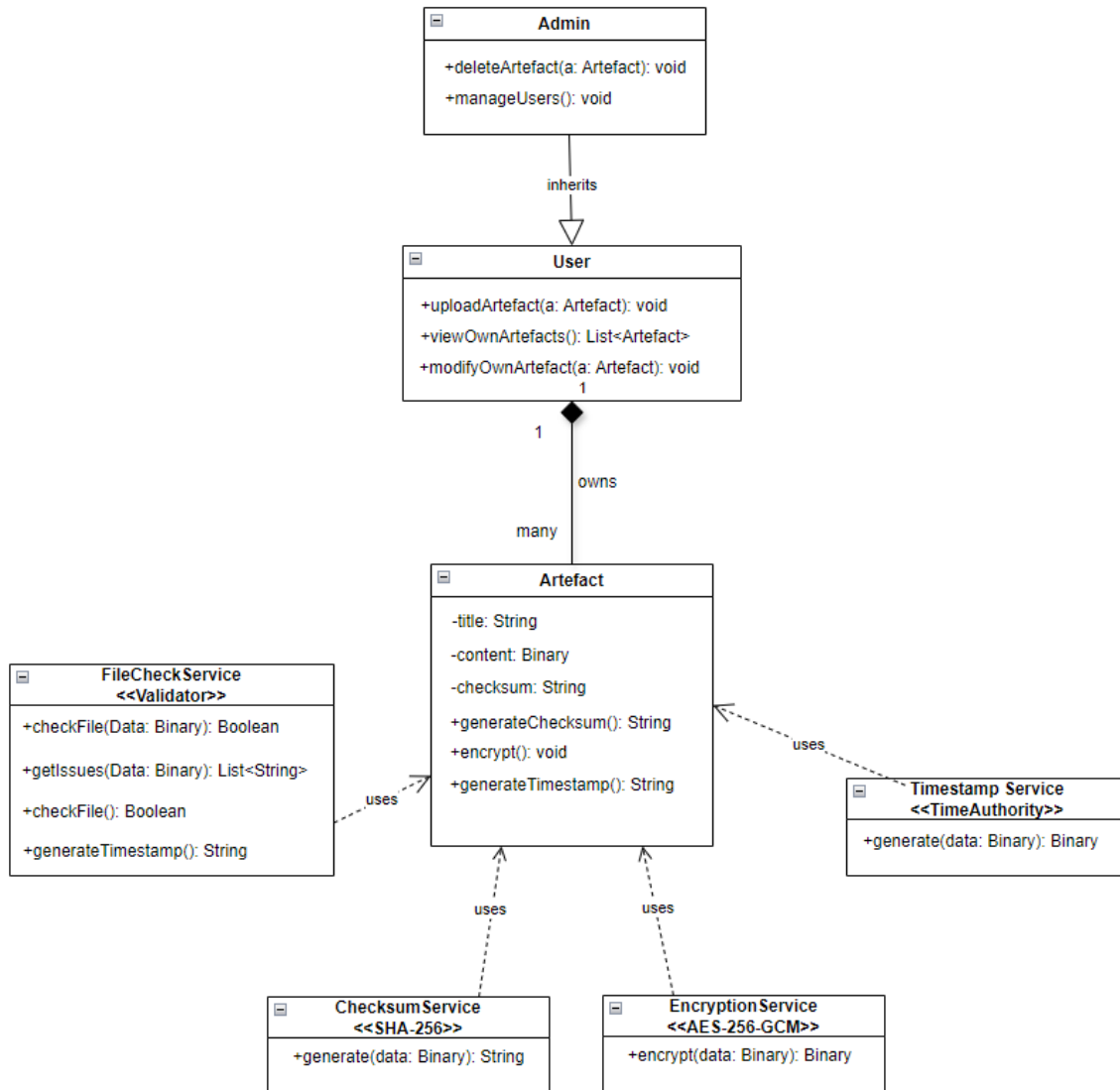


Figure 02: Class Diagram

Admin inherits from user, giving them the regular user privileges, alongside elevated rights to delete artefacts and modify user accounts. Users can own many artefacts. Artefacts use automated services.

Design Pattern

The design has a modular monolithic structure and a pipeline design pattern. Linear workflow allows services to be called sequentially as modules. This structure prevents dependencies and allows for future growth (Brown, Woolf and Yoder, 2025), as seen in the following diagram:

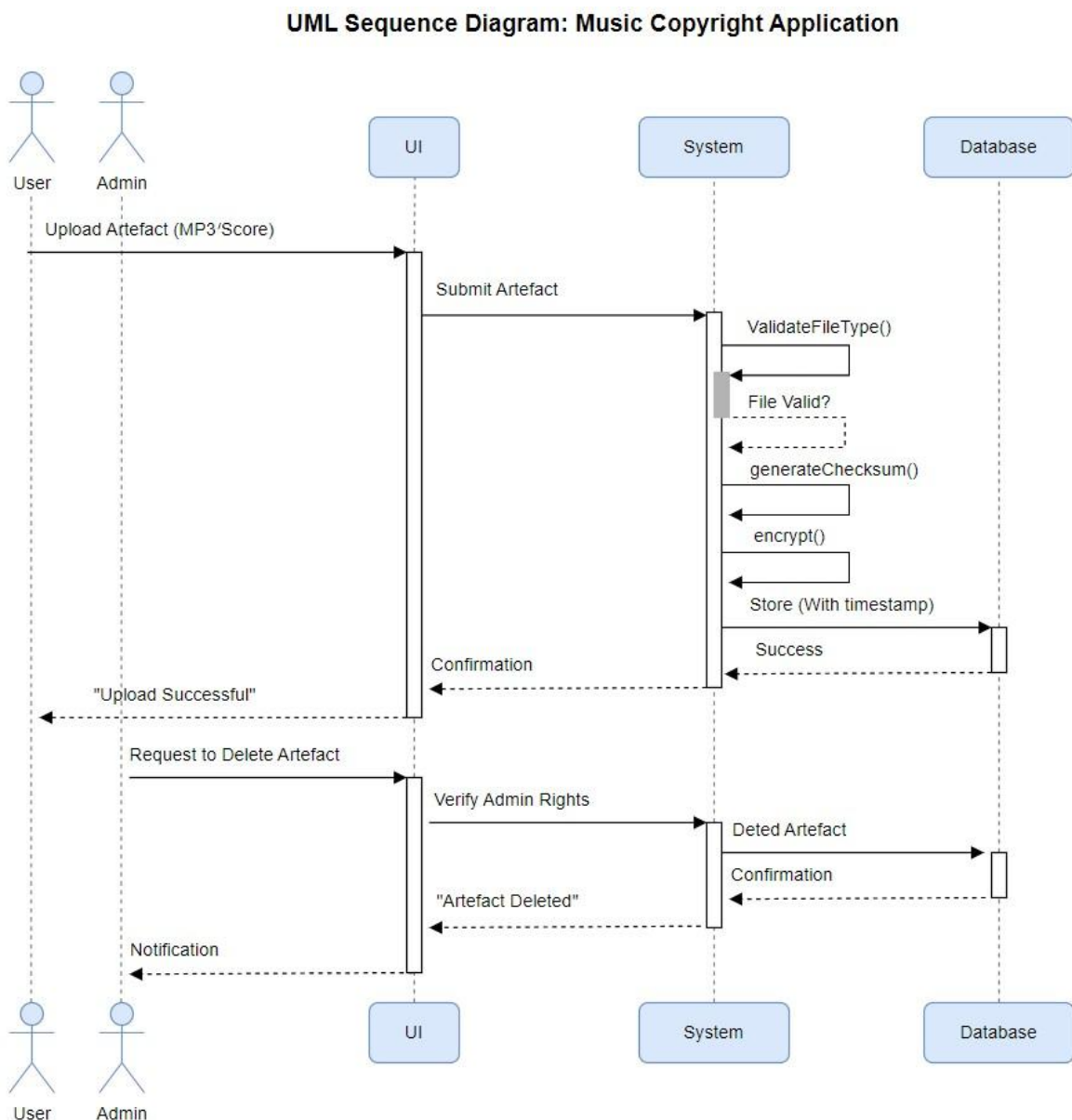


Figure 03: Sequence diagram

Database Design

On completion of the automated services, artefacts are stored in a database. The team recognised storing large audio files in this way can potentially cause performance issues. Storing the audio file in a server and storing the file path in the database was discussed as an alternative but was deemed too complex. (Stonebraker and Cattell, 2022).

Future Considerations

Additional security elements were discussed but were deemed outside of scope, or too complicated to fit in with our goal of a simple application.

These included a login function supported by multi-factor authentication, the most effective guard against password attacks (OWASP, n.d.), and audit logging as a method of ensuring administrative actions are themselves accountable (ISO/IEC, 2022).

Summary

The application has been designed to be straightforward and to focus on security. This led to a pipeline design pattern, modular monolith architecture and use of a single database. Additional elements were judged to make the design too complex and would be added to future versions.

Reference list

Brown, K., Woolf, B., and Yoder, J. (2025) *Cloud Application Architecture Patterns*. United States of America: O'Reilly Media Inc.

Ferraiolo, D., Kuhn, D.R. and Hu, V.C. (2023) *Role-Based Access Control*. 3rd ed. New York: Artech House. Available from institutional access or publisher.

Garg, P., Taneja, S. and Kumar, R. (2023) Secure integrity verification for multimedia artefacts using enhanced SHA-3 algorithms. *Multimedia Tools and Applications*, 82, pp.17593–17612. <https://doi.org/10.1007/s11042-023-15133-w>

ISO/IEC. (2022) *Information Security, Cybersecurity and Privacy Protection – Information Security Management Systems – Requirements (ISO/IEC 27001:2022)*. Geneva: International Organization for Standardization. Available from: <https://www.iso.org/standard/82875.html>

Khan, M.A., Farooq, Q.U. and Awan, M.A. (2022) Secure artefact storage using hybrid cryptographic frameworks in cloud environments. *Journal of Cloud Computing*, 11(1), pp.1–19. <https://doi.org/10.1186/s13677-022-00282-6>

Liu, Y., Wang, L. and Yu, H. (2023) Data provenance frameworks for secure file handling in digital systems. *Future Generation Computer Systems*, 139, pp.1–14. <https://doi.org/10.1016/j.future.2022.08.001>

Odeh, N. and Hijazi, S. (2023) Detecting and Preventing Common Web Application Vulnerabilities: A Comprehensive Approach. *International Journal of Information Technology and Computer Science*, 15(3), pp. 26–41. Available from: <https://doi.org/10.5815/ijitcs.2023.03.03> [Accessed 17 May 2025].

OWASP Foundation. (2025) File Upload Cheat Sheet. Available from: [https://cheatsheetseries.owasp.org/cheatsheets/File Upload Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html) [Accessed 17 May 2025].

OWASP Foundation. (2024) OWASP Top Ten Proactive Controls 2024. Available from: <https://top10proactive.owasp.org/archive/2024/> [Accessed 11 May 2025].

OWASP Foundation. (2018) OWASP Top Ten Proactive Controls 2018. Available from: <https://top10proactive.owasp.org/archive/2018/0x02-about-project/> [Accessed 11 May 2025].

OWASP Foundation. (no date) *Multifactor authentication cheat sheet*. Available from: [https://cheatsheetseries.owasp.org/cheatsheets/Multifactor Authentication Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html) [Accessed 13 May 2025].

Peltier, T.R. (2023) *Information Security Policies, Procedures, and Standards: Guidelines for Effective Information Security Management*. 3rd ed. Boca Raton: CRC Press. <https://doi.org/10.1201/9781003261340>

Poston, H. (2020) *Improper Error Handling*, Infosec. Available from: <https://www.infosecinstitute.com/resources/secure-coding/improper-error-handling/> [Accessed 11 May 2025].

Sharma, R. and Verma, G. (2022) Enhancing digital rights management using smart contracts and timestamps. *Computers & Security*, 116, 102614. <https://doi.org/10.1016/j.cose.2022.102614>

Shema, M. & Alcover, J. B. (2012) *Hacking web apps: detecting and preventing web application security problems*. 1st edition. Waltham, Mass: Syngress.

Zhou, Y., Zhang, J. and Chen, X. (2023) Blockchain-based timestamping in digital copyright systems: A review. *Information Processing & Management*, 60(2), 103216. <https://doi.org/10.1016/j.ipm.2022.103216>